

Final Exam Questions

Which is (are) a correct statement(s) from the following?

1. Cyber Threat Intelligence (CTI) can be used in the incident response process. ✓
2. It is desirable for an organisation to endeavour to defend against all potential threats. ✗
3. CTI providers will generally supply operational threat intelligence in a human readable format only. ✗
4. CTI providers will generally supply Techniques, Tactics and Procedures (TTPs) in a machine-readable format only. ✗
5. Microsoft Threat Intelligence Center does not aggregate data from botnets for safety. ✗



- a. 1
- ☐ b. 2 and 5
- ☐ c. 3
- ☐ d. None of the options
- ☐ e. 4

[Clear my choice](#)

Which is (are) a correct statement(s) from the following?

1. For the IaaS model, the vast majority of the information relevant to an incident response is in the possession of the cloud provider. ✗
2. Among IaaS, PaaS and SaaS, the company's responsibility is the highest in SaaS. ✗
3. For the IaaS model, customers should review the cloud provider policy before requesting any data. ✓
4. For the IaaS model, customers have full control of the virtual machine but do not have complete access to all logs provided by the operating system. ✗
5. For containment of IR process in clouds, the cloud provider's capabilities to isolate an incident should be revisited. ✓

- ☒ a. 3 and 5
- ☐ b. 1, 2 and 5
- ☐ c. 2 and 3
- ☐ d. 1, 2
- ☐ e. 3, 4 and 5

[Clear my choice](#)

Question 3

Answer saved

Marked out of
2.00

Flag question

Which is (are) an incorrect statement(s) from the following?

1. Metasploit provides many exploits and payloads for network attacks. ✓
2. msvenom can generate a payload for a backdoor. ✗
3. Data manipulation attacks can happen when there is a lack of a mechanism for checking the integrity of data. ✓
4. Fuzzing is originally a software testing technique, which provides valid inputs to a given program to see how it reacts to the inputs. ✗
5. Smartphones' web-supported apps can be exploitable through the man-in-the-middle attack. ✓

- ☐ a. 1 and 3
- ☒ b. None of the options
- ☐ c. 1, 2 and 4
- ☐ d. 2 and 3
- ☐ e. 1, 2, 3 and 4

[Clear my choice](#)

Question 4

Answer saved

Marked out of
2.00

Flag question

Which is (are) a correct statement(s) from the following?

1. John the Ripper, THC Hydra and Nmap are password cracking tools. ✗
2. Hackers sometimes try to sell the data obtained from exfiltration. ✓
3. Phishing cannot be classified as an external reconnaissance technique. ✗
4. Inefficient neutralization leads to false positives in threat life cycle management. ✗
5. The discovery phase in threat life cycle management is solely conducted through software. ✗

- ☐ a. 1
- ☐ b. 4 and 5
- ☐ c. 1, 3 and 5
- ☒ d. 2 and 4
- ☐ e. 2

[Clear my choice](#)

Question 5

Answer saved

Marked out of 2.00

Flag question

Which is (are) an incorrect statement(s) from the following?

1. Behaviour analytics can be one layer of defence in the defence-in-depth approach. ✓
2. The traditional defender mindset focuses on monitoring only high profile users. ✓
3. A large number of requests for the same file can be an IoC. ✓
4. Current threat actors are interested in compromising regular users. ✓
5. Infected hosts send command and control communications masked as DNS requests over port 80. ✗

- ☒ a. None of the options
- ☐ b. 4
- ☐ c. 1
- ☐ d. 2
- ☐ e. 3 and 5

[Clear my choice](#)

Question 6

Answer saved

Marked out of 2.00

Flag question

Which is (are) a correct statement(s) from the following?

1. Reciprocation, scarcity, consistency, ^{liking} ~~sincerity~~, authority and validation are six levers of social engineering. ✗
2. To perform baiting, an attacker will leave a malware-infected external storage device in a place where other people can easily find it. ✓
3. The water holing attack targets the general public. ✗
4. Attackers can guess passwords from social media postings. ✓
5. Social engineering attacks can be beyond the protection of security tools. ✓

- ☐ a. 2 and 3
- ☒ b. 2, 4 and 5
- ☐ c. 2 and 5
- ☐ d. 1 and 3
- ☐ e. 1, 4 and 5

[Clear my choice](#)

What is the Windows system's feature used to give permissions to the program, elevate their privileges and run with admin-level privileges? User Access Control (UAC)

Answer: User Account Control (UAC)

Question 8

Answer saved

Marked out of 3.00

Flag question

Which is (are) a correct statement(s) from the following?

1. Internal reconnaissance is done off-site. ✗
2. Internal reconnaissance is an active attack. ✗
3. Internal reconnaissance is used to determine the security mechanisms are in place to avert hacking attempts. ✓
4. Sniffing tools are designed to capture the packets and present them in a human-readable format. ✓
5. Wireshark can be considered as a tool for internal reconnaissance. ✓

- ☐ a. 3 and 4
- ☐ b. 1, 3 and 5
- ☐ c. 1 and 5
- ☒ d. 3, 4 and 5
- ☐ e. 1, 2 and 3

[Clear my choice](#)

Question 9

Answer saved

Marked out of 2.00

Flag question

What is the phase for complementing the premature ending of the previous analyses of threat and vulnerability in vulnerability management called? Remediation

Answer: Remediation

Question 10

Answer saved

Marked out of
2.00

Flag question

Which is (are) an incorrect statement(s) from the following?

1. Two reasons for having network segmentation are performance and security. ✓
2. Establishing an appropriate physical network segmentation involves understanding the logical distribution of resources according to the company's needs. ✓
3. VLANs are separated physically not logically. ✗
4. No data can flow between the segmented networks even though there is another switch or router. ✗
5. Physical network segmentation will provide good isolation, but there is a scalability issue. ✓

- ☐ a. 1, 2 and 4
- ☒ b. 3 and 4
- ☐ c. 3 and 5
- ☐ d. 2 and 4
- ☐ e. 1, 2, 3 and 4

[Clear my choice](#)

Question 11

Answer saved

Marked out of
3.00

Flag question

What is the name of the account used for Microsoft's implementation of Kerberos but was compromised during the pass-the-ticket attack? `KRB TGT`

Answer:

Question 12

Answer saved

Marked out of 2.00

Flag question

Which is (are) an incorrect statement(s) from the following?

1. Credential theft could be the first step in the attack to get an opportunity to escalate privileges to a domain administrator. ✓
2. For apps that users are paying for as a service, measures should be taken to ensure that the apps are using a security framework throughout the software development lifecycle. ✗
3. Systems developed by individual departments give IT managers the visibility they need to know how employees are using them. ✗
4. As countermeasures for data at rest, file encryption or disk encryption can be employed.
5. Lack of diligence and untrained employees are considered the top causes of data breaches. ✓

- ☐ a. 2
- ☐ b. 1, 4 and 5
- ☐ c. 2 and 5
- ☒ d. 2 and 3
- ☐ e. 3

[Clear my choice](#)

Question 13

Answer saved

Marked out of 3.00

Flag question

Which is (are) a correct statement(s) from the following?

1. The 183m GBP fines imposed on British Airways in 2018 were under the GDPR. ✓
2. Privacy is the right to protect the subject's personal information but does not extend to their personal space. ✗
3. The term "confidentiality" is used to refer to "secrecy" in cryptography. ✓
4. Privacy is secrecy for the benefit of the organisation, while confidentiality is secrecy for the benefit of the individual. ✗
5. Solidifying protection system is enough for the security posture of the organisation. ✗

- ☐ a. 2 and 3
- ☐ b. 1 and 4
- ☒ c. 1 and 3
- ☐ d. 1, 3 and 5
- ☐ e. 1 and 5

[Clear my choice](#)

Question 14

Answer saved

Marked out of
3.00

Flag question

Which is (are) an incorrect statement(s) from the following?

1. The amount of time required for a "targeted attack" is usually short. ✗
2. As government-sponsored cyber attacks happen on a large scale, the private sector can ignore them. ✗
3. Estimated Time to Detection (ETTD) is one of the metrics for which the Red team has accountability. ✗
4. The traditional "prevent breach" approach promotes ongoing testing. ✗
5. There is no way for an attacker to compromise two factor authentication. ✗

- ☒ a. All of the options
- ☐ b. 1, 2, 3 and 5
- ☐ c. 2, 3, 4 and 5
- ☐ d. 1, 3 and 5
- ☐ e. 5

[Clear my choice](#)

Question 15

Answer saved

Marked out of
3.00

Flag question

Which is (are) a correct statement(s) from the following?

1. Endpoints in the defence-in-depth approach refer to human users only. ✗
2. Patch management is not an example of security controls. ✗
3. The defence-in-depth approach will delay the attack. ✗
4. As the defence-in-depth approach is concerned with layers, its implementation does cover documents in transit. ✓
5. Two forms of infrastructure in the defence-in-depth approach are on-premises and PaaS. ✗

- ☐ a. 3
- ☐ b. 1 and 3
- ☐ c. 1
- ☐ d. 3 and 5
- ☒ e. 4

[Clear my choice](#)

Question 16

Answer saved

Marked out of
3.00

Flag question

Which is (are) an incorrect statement(s) from the following?

1. Data exfiltration is not an option for lateral movement attackers. ✗
2. It is usually acceptable for the attacker to raise alerts when they perform lateral movement. ✗
3. Lateral movement can be performed before compromising the system. ✗
4. In lateral movement, attackers move horizontally in the same system. ✗
5. Lateral movement is a short-term campaign. ✗

- ☐ a. 3
- ☒ b. All of the options
- ☐ c. 3 and 4
- ☐ d. 5
- ☐ e. 1

[Clear my choice](#)

Question 17

Answer saved

Marked out of
2.00

Flag question

What is not a stage of risk assessment?

1. Scope identification ✓
2. Vulnerability analysis ✓
3. Collecting data ✓
4. Analysis of recovery plan ✗
5. Threat analysis ✓

- ☐ a. 2
- ☐ b. 1
- ☐ c. 5
- ☒ d. 4
- ☐ e. 3

[Clear my choice](#)

Question 18

Answer saved

Marked out of
2.00

Flag question

Which is (are) a correct statement(s) from the following?

1. In small-sized organizations, it might be easier to aggregate resources according to their departments. ✓
2. Cross VLAN will be suitable for large networks. ✗
3. SSH is recommended to manage switches and routers in the network. ✓
4. Network Access Control (NAC) systems do not perform end-user authentication. ✗
5. Security for Virtual Machines can be relaxed. ✗

- ☒ a. 1 and 3
- ☐ b. 2
- ☐ c. 3, 4 and 5
- ☐ d. 1 and 2
- ☐ e. 1

[Clear my choice](#)

Question 19

Answer saved

Marked out of
3.00

Flag question

Which is (are) a correct statement(s) from the following?

1. Policy should be updated only regularly. ✗
2. Policy should have well-defined scopes. ✓
3. The description of policy is more technical compared with procedure. ✗
4. Policy could be not enforced sometimes. ✗
5. Policy could include industry standards. ✓

- ☐ a. 2 and 3
- ☒ b. 2 and 5
- ☐ c. 2 and 4
- ☐ d. 1, 3 and 4
- ☐ e. 3 and 5

[Clear my choice](#)

Question 20

Answer saved

Marked out of
2.00

Flag question

Which one is not a foundational area of an IR process?

1. Scope ✓
2. Objective ✓
3. Roles ✓
4. Assessment ✗
5. Definition/Terminology ✓

- ☐ a. 3
- ☒ b. 4
- ☐ c. 2
- ☐ d. 5
- ☐ e. 1

[Clear my choice](#)

Question 21

Answer saved

Marked out of
2.00

Flag question

Which is (are) a correct statement(s) from the following?

1. Horizontal privilege escalation attacks are normally facilitated by techniques that compromise login credentials. ✓
2. In horizontal privilege escalation, the attacker uses a root account to access the accounts of other normal users. ✗
3. Vertical escalation techniques are the same across all systems. ✗
4. In Windows, administrator access should be given to normal users as it is convenient for them. ✗
5. In Windows, it is impossible to copy access tokens from existing processes started by admin user to a new Windows process. ✓

- ☒ a. 1
- ☐ b. 3 and 5
- ☐ c. 4
- ☐ d. 1 and 3
- ☐ e. 2

[Clear my choice](#)

Question 22

Answer saved

Marked out of
3.00

Flag question

Which is (are) an incorrect statement(s) from the following?

1. Best practices can be a part of guidelines. ✓
2. The security awareness program must be in line with legal requirements. ✓
3. Guidelines can be optional but can also be additionally recommended guidance. ✓
4. NIST Special Publication 800-53, organizations are not allowed to have flexibility in applying the baseline security controls as this may cause confusion. ✗
5. Users will more easily remember the items if a real scenario is given in security awareness training. ✓

- ☐ a. 1 and 5
- ☒ b. 4
- ☐ c. None of the options
- ☐ d. 3 and 4
- ☐ e. 2 and 3

[Clear my choice](#)

Question 23

Answer saved

Marked out of
2.00

Flag question

What is a key principle of GDPR, which requires training staff in data protection measures and regularly evaluating and data handling processes? Accountability

Answer: Accountability

Question 24

Answer saved

Marked out of
2.00

Flag question

What is the name of malware (or cyberweapon), believed to be developed by NSA and became the basis for the WannaCry ransomware? EternalBlue

Answer: EternalBlue

Question 25

Answer saved

Marked out of
2.00

Flag question

Which is (are) an incorrect statement(s) about an incident response (IR) process?

1. Response in the IR process refers to how to rapidly respond to incidents. ✓
2. Many companies fail to constantly review the IR process. ✓
3. If there is no IR process in process, the company/organisation will have a bad security posture. ✓
4. Good sensors will result in a successful IR process. ✓
5. It is unnecessary to record every step of the IR process. ✗

- ☐ a. None of the options
- ☐ b. 1 and 4
- ☒ c. 5
- ☐ d. 2 and 5
- ☐ e. 3

[Clear my choice](#)

Question 26

Answer saved

Marked out of
3.00

Flag question

Which is (are) a correct statement(s) from the following?

1. WannaCry can be regarded as an extortion attack. ✓
2. Logistically, it is simpler to sell stolen data to third parties than to blackmail a data owner. ✗
3. Data manipulation attacks can happen when there is a lack of a mechanism for checking the integrity of data. ✓
4. Backdoors can enable hackers to decrypt traffic flowing through the firewalls. ✓
5. Smartphones' web-supported apps can be exploitable through the man-in-the-middle attack. ✓

- ☐ a. 1, 2, 3 and 4
- ☐ b. 1 and 3
- ☒ c. 1, 3, 4 and 5
- ☐ d. 1, 2 and 4
- ☐ e. 2 and 3

[Clear my choice](#)

Question 27

Answer saved

Marked out of
2.00

Flag question

What technology should be used if a company wants to have a secure private channel of communication between the main corporate network and the remote network?

Virtual
Private
Network

Answer: Virtual Private Network (VPN)

Question 28

Answer saved

Marked out of
2.00

Flag question

What does an individual need to request to find out what a company or organisation knows about the individual under GDPR?

Subject Access Request (SAR)

Answer: Subject Access Request (SAR)

Question 29

Answer saved

Marked out of
3.00

Flag question

Which is (are) a correct statement(s) from the following?

1. Most of the failures in the BYOD scenario are because of the poor manufacturing quality of devices, which leads to an insecure implementation. ✗
2. The connectivity between BYOD devices and on-premises does not have to be considered in the threat landscape. ✗
3. An example of a PaaS service is Google Docs. ✗
4. Accessing corporate SaaS applications from a compromised device that has no direct connectivity with on-premise resources cannot compromise the company's data. ✗
5. Security awareness training cannot be considered the main protection as technical security controls are more important. ✗

- ☐ a. 1
- ☐ b. 2 and 5
- ☐ c. 1, 3 and 4
- ☐ d. 3 and 4
- ☒ e. None of the options

[Clear my choice](#)

Question 30

Answer saved

Marked out of
2.00

Flag question

Which is (are) a correct statement(s) from the following?

1. The default relationship between the parent domain and the child domain in Active Directory is a transitive one-way trust. ✗
2. Domain Name System in Active Directory is hierarchical. ✓
3. A change in Group Policy in Active Directory is permanent. ✗
4. Group Policy Object defines how a system will behave for a defined group of users. ✓
5. The group policies can be segmented using organizational units (OUs) and deployed accordingly. ✓

- ☐ a. 1, 3 and 5
- ☐ b. 3
- ☐ c. 1 and 3
- ☐ d. 2 and 4
- ☒ e. 2, 4 and 5

[Clear my choice](#)

Question 31

Answer saved

Marked out of
2.00

Flag question

What is an example of profiling motivation, from which a group of hackers expresses a political preference to just an expression for a particular cause? *Hacktivism*

Answer:

Question 32

Answer saved

Marked out of 3.00

Flag question

Which is (are) an incorrect statement(s) from the following?

1. Network Intrusion Detection System (NIDS) shields an organisation's system to prevent internal reconnaissance even when the hackers are scanning individual targets. ✗
2. By using legitimate tools for lateral movement, hackers can move around in highly secured networks. ✓
3. Sysinternals gives alerts to users on a remote system when it is in operation. ✗
4. Sysinternals can be used to reveal information about running processes. ✓
5. Windows PowerShell can be used as a legitimate tool for lateral movement. ✓

- ☒ a. 1 and 3
- ☐ b. 1
- ☐ c. 1, 4 and 5
- ☐ d. 2 and 4
- ☐ e. 3

[Clear my choice](#)

Question 33

Answer saved

Marked out of 3.00

Flag question

Which is (are) a correct statement from the following?

1. Reverse engineering will generate assembly language codes from machine-executable codes. ✓
2. Buffer overflows are caused by not observing the memory restrictions of the buffer. ✓
3. The success rate of the source code analysis is high as it could be conducted by a knowledgeable hacker. ✗
4. The Structured Exception Handling (SEH) exploit cannot be used with the buffer overflows exploit. ✗
5. Government agencies do not find or develop Zero-Days. ✗

- ☐ a. 1 and 5
- ☒ b. 1 and 2
- ☐ c. 2, 3 and 4
- ☐ d. 2 and 5
- ☐ e. 1

[Clear my choice](#)

Question **34**

Answer saved

Marked out of
2.00

Flag question

What is a technology for servers to achieve redundancy of disks?

Answer: Redundant Array of Independent Disks (RAID)

Redundancy
Array of
Independent
Disk
(RAID)Question **35**

Answer saved

Marked out of
2.00

Flag question

What is a course of action designed to help an organization respond effectively to a significant future event or situation that may or may not happen?

Answer: Contingency Plan

Contingency Plan

Question **36**

Answer saved

Marked out of
3.00

Flag question

Which is (are) a correct statement(s) from the following?

1. The Registry in Windows cannot be remotely modified. ✗
2. WMI was a key tool in a famous hack on Sony Pictures in 2014. ✓
3. Attackers use scheduled tasks in Windows to steal data. ✓
4. WMIImplant was developed by Microsoft. ✗
5. The attackers can deploy PowerShell scripts to run as scheduled tasks on Windows machines. ✓

- ☐ a. 2 and 3
- ☒ b. 2, 3 and 5
- ☐ c. 2, 4 and 5
- ☐ d. All of the options
- ☐ e. 1

[Clear my choice](#)

Question 37

Answer saved

Marked out of
3.00

Flag question

Which is (are) a correct statement(s) from the following?

1. The senior management group will determine the scope of a disaster recovery plan. ✓
2. A thorough disaster recovery plan will be made in consideration of the worst-case scenario. ✓
3. Policies are not the key areas that need to be prioritized in the making of a disaster recovery plan. ✗
4. The Disaster Recovery (DR) team needs to determine the minimum possible time that each department can operate without critical systems. ✗
5. The DR team has a sole responsibility to approve a disaster recovery plan. ✗

- ☐ a. 1 and 2
- ☒ b. 2
- ☐ c. 2 and 4
- ☐ d. 3 and 4
- ☐ e. 5

[Clear my choice](#)

Question 38

Answer saved

Marked out of
4.00

Flag question

Which is (are) a correct statement(s) from the following?

1. One of the Petya IoCs is the local network scanning attempt on TCP ports 443 and 445. ✗
2. HIDS (Host-based IDS) monitors the inbound and outbound packets within the subnet only. ✗
3. NIDS (Network-based IDS) is located at a strategic point. ✓
4. NIDS takes a snapshot of existing system files and matches it to the previous one. ✗
5. Anomaly-based IDS needs to establish a baseline model of trustworthy activity. ✓

- ☒ a. 3 and 5
- ☐ b. 3
- ☐ c. 1, 3 and 5
- ☐ d. 1 and 2
- ☐ e. 3 and 4

[Clear my choice](#)

Question 39

Answer saved

Marked out of
2.00

Flag question

Which is (are) an incorrect statement from the following?

1. Insider threats are people working inside organizations that have malicious intentions. ✓
2. In SQL injection, attackers supply inputs that can manipulate the execution of SQL. ✓
3. Cross-site scripting exploits the non-sanitised input fields of websites. ✓
4. Broken authentication happens often in publicly shared computers. ✓
5. Botnets exclude IoT devices. ✗

- ☐ a. None of the options
- ☐ b. 3 and 5
- ☒ c. 5
- ☐ d. 1 and 2
- ☐ e. 2 and 4

[Clear my choice](#)

Question 40

Answer saved

Marked out of
3.00

Flag question

Which is (are) a correct statement(s) from the following?

1. Hackers do not rent bots. ✗
2. It is not possible for users to utilize the same password for multiple credentials. ✗
3. The hackers who want to infiltrate without making any noise use the DDOS attack. ✗
4. The traditional network perimeter is sufficient to describe the security boundary of organisations. ✗
5. The majority of the credential consists only of a username and password. ✓

- ☐ a. 4
- ☐ b. None of the options
- ☒ c. 2, 3 and 5
- ☐ d. 1 and 5
- ☐ e. 5

[Clear my choice](#)